

UD1: Fundamentos de Seguridad y Gestión del Riesgo

Bloques 1 · 2 · 3 | 20 horas

Marco normativo: RD 311/2022 ENS · ISO/IEC 27001:2022 · MAGERIT v3 · RGPD/LOPDGDD

Contexto UE: Directiva NIS2 · Anteproyecto Ley Ciberseguridad (tramitación 2025-2026)

Contenidos de la Unidad

01

Criterios generales de seguridad

Modelos, amenazas, salvaguardas

02

Análisis de Impacto de Negocio (BIA)

CIA, procesos críticos, SLA

03

Gestión de Riesgos

MAGERIT v3, ISO 27005, controles

04

Marco normativo vigente

ENS RD 311/2022, NIS2, RGPD, ISO 27001

01

Criterios Generales de Seguridad



Bloque 1 · Modelo de riesgo, amenazas, salvaguardas, ciclo PDCA

PROCESOS DE NEGOCIO

ANÁLISIS DE RIESGOS

SALVAGUARDAS & CONTROLES

MONITORIZACIÓN CONTINUA

Principios ENS (RD 311/2022)

- ▶ Seguridad integral
- ▶ Gestión del riesgo
- ▶ Prevención, detección, respuesta
- ▶ Líneas de defensa
- ▶ Reevaluación periódica
- ▶ Función diferenciada

La seguridad no es un producto, es un proceso continuo de gestión del riesgo alineado con el negocio

AMENAZAS

- Malware / Ransomware
- Acceso no autorizado
- Ingeniería social / Phishing
- DoS / DDoS
- Amenaza interna (insider)
- Vulnerabilidades 0-day
- APT (Amenaza Persistente Avanzada)

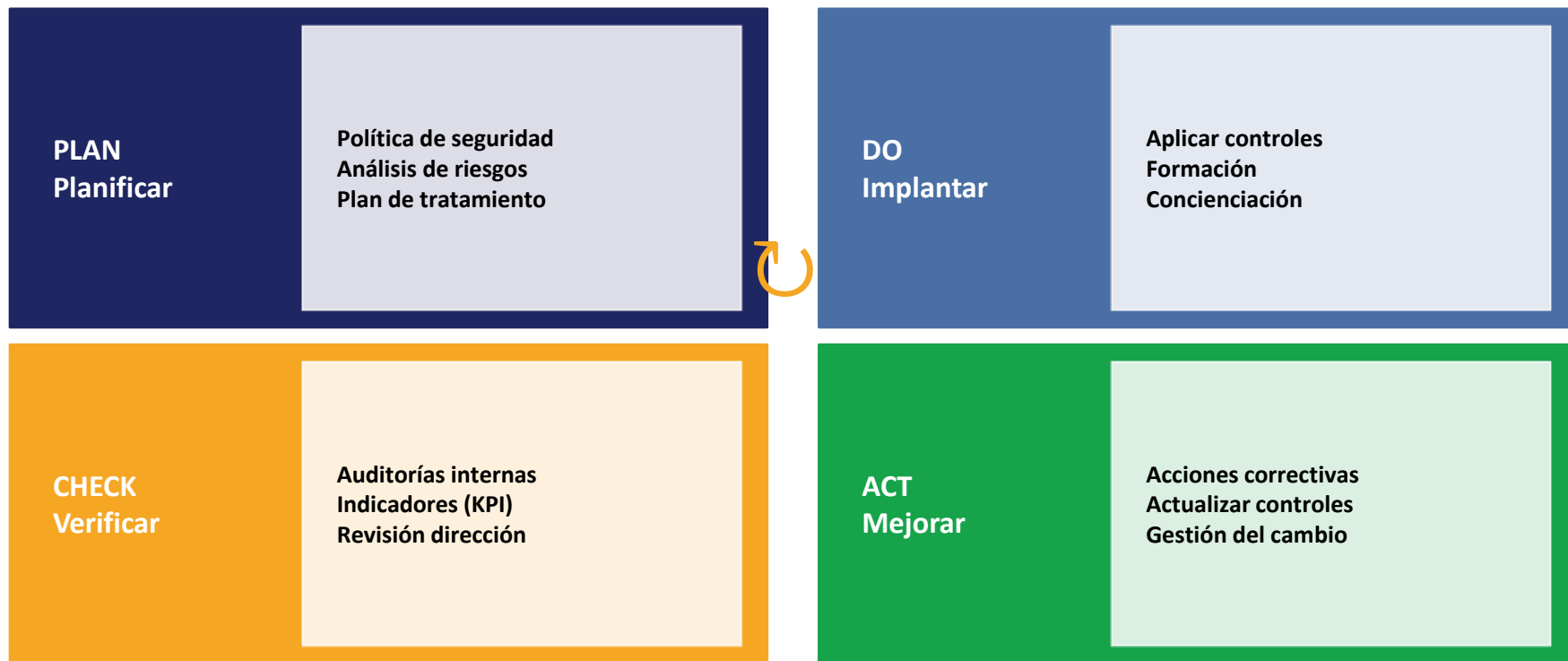
RIESGOS

- Probabilidad $\times$ Impacto
- Pérdida de confidencialidad
- Pérdida de integridad
- Pérdida de disponibilidad
- Incumplimiento normativo
- Daño reputacional
- Pérdida económica

SALVAGUARDAS

- Antimalware / EDR
- Control de acceso (IAM)
- Concienciación y formación
- Firewall / IDS/IPS
- Cifrado de datos
- Copias de seguridad
- Gestión de parches

 Las salvaguardas deben ser proporcionales al riesgo (principio de proporcionalidad ENS)



Ciclo PDCA — base del SGSI según ISO/IEC 27001:2022 y del proceso de mejora continua del ENS

02

Análisis de Impacto de Negocio (BIA)



Bloque 2 · Procesos críticos, tríada CIA, RTO/RPO

¿Qué es el BIA?

El Business Impact Analysis identifica los procesos críticos de la organización y determina el impacto que tendría su interrupción en términos de:

- Pérdida económica
- Daño reputacional
- Incumplimiento legal
- Pérdida de datos

Es el punto de partida para definir los requisitos de seguridad (CIA) de cada sistema.

Tríada CIA — Pilares de la Seguridad

C — Confidencialidad

Solo acceden quienes están autorizados. Cifrado, control de acceso, clasificación de la información.

I — Integridad

Los datos no son alterados sin autorización. Hashing, firma digital, auditoría de cambios.

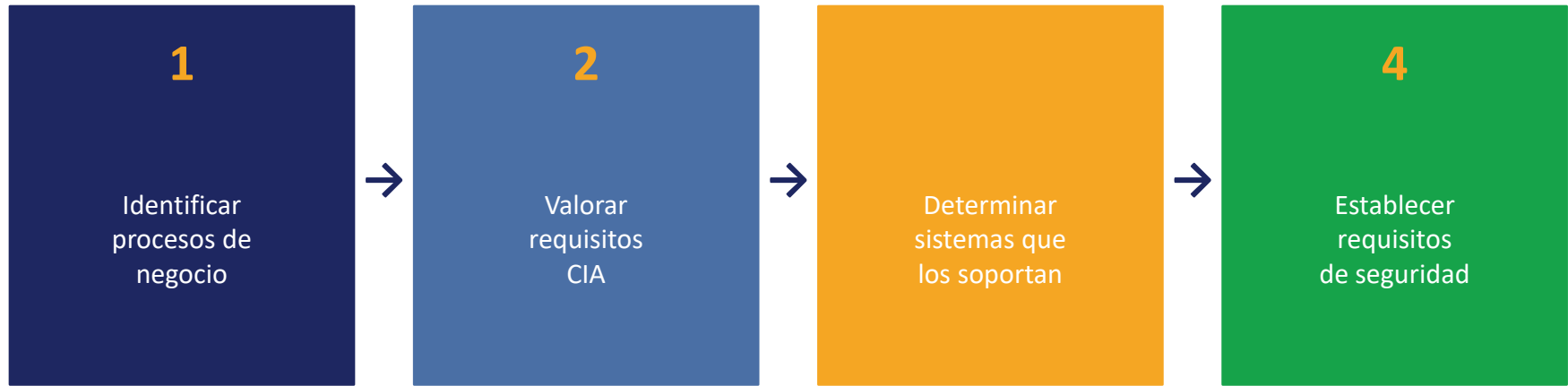
A — Disponibilidad

El sistema opera cuando se necesita. Redundancia, copias de seguridad, SLA, RTO/RPO.

RTO (Recovery Time Objective) y RPO (Recovery Point Objective) son métricas clave del BIA

Proceso BIA: de los procesos al sistema de información

Bloque 2



Ejemplo de valoración de sistemas (nivel Básico / Medio / Alto según ENS)

Proceso	Sistema	Confidencialidad	Integridad	Disponibilidad
Facturación	ERP	ALTO	ALTO	ALTO
RR.HH.	SIRH	ALTO	MEDIO	MEDIO
Producción	SCADA/MES	MEDIO	ALTO	ALTO
Comunicación	Correo corporativo	MEDIO	MEDIO	MEDIO

03

Gestión de Riesgos



Bloque 3 · MAGERIT v3, ISO 27005, matrices de riesgo



$$\text{RIESGO} = \text{Probabilidad} \times \text{Impacto}$$

Probabilidad →

	MEDIO	ALTO	ALTO
↑ Impacto	BAJO	MEDIO	ALTO
o	BAJO	BAJO	MEDIO

Opciones de tratamiento del riesgo

Aceptar: Riesgo residual asumible

Mitigar: Aplicar controles/salvaguardas

Transferir: Seguros, externalización

Evitar: Eliminar la actividad

MAGERIT (Metodología de Análisis y Gestión de Riesgos de los sistemas de información de las Administraciones públicas) — v3 publicada por el CCN (2012), metodología oficial en España alineada con ISO/IEC 27005

Libro I El Método

- › Marco de trabajo
- › Proceso de análisis
- › Proceso de gestión
- › Proyectos de A&G de riesgos
- › Plan de seguridad

Libro II Catálogo de Elementos

- › Tipos de activos
- › Dimensiones de seguridad (CIA+AT)
- › Criterios de valoración
- › Amenazas típicas
- › Salvaguardas

Libro III Guía de Técnicas

- › Técnicas específicas
- › Análisis mediante tablas
- › Algoritmos de cálculo
- › Árboles de ataque
- › Técnicas de planificación

Herramientas: PILAR (CCN) · EAR/PILAR · Integrable con ENS y esquemas de certificación ISO 27001

04

Marco Normativo Vigente



ENS RD 311/2022 · NIS2 · RGPD/LOPDGDD · ISO 27001:2022

RD 311/2022 — ENS <i>Nacional</i>	Principios, categorías (Básica/Media/Alta), medidas de seguridad. Obligatorio sector público y proveedores TIC. Certificación obligatoria desde mayo 2024.
RGPD (UE) 2016/679 + LOPDGDD LO 3/2018 <i>Nacional/UE</i>	Protección de datos personales. Principios, derechos ARCO+, delegado de protección de datos (DPO), notificación de brechas en 72h a la AEPD.
Directiva NIS2 (UE) 2022/2555 <i>UE / En tramitación ES</i>	Ciberseguridad de entidades esenciales e importantes. Notificación 24h/72h/1 mes. RD-ley 7/2025 (transposición parcial). Ley pendiente en Cortes.
ISO/IEC 27001:2022 — SGSI <i>Internacional</i>	Sistema de Gestión de Seguridad de la Información. Marco de referencia internacional, complementa ENS. Controles en Anexo A (93 controles vs 114 de 2013).
MAGERIT v3 (CCN) <i>Nacional / Metodología</i>	Metodología oficial española de análisis y gestión de riesgos. Tres libros: Método, Catálogo de Elementos, Guía de Técnicas.

Resumen UD1

1

La seguridad informática es un proceso continuo de gestión del riesgo, no un estado final

2

El BIA identifica procesos críticos y determina requisitos CIA (Confidencialidad, Integridad, Disponibilidad)

3

MAGERIT v3 es la metodología oficial española: identificar activos → amenazas → riesgo → tratamiento

4

El ENS (RD 311/2022) es obligatorio para el sector público y sus proveedores TIC desde 2022; certificación desde mayo 2024

5

NIS2 amplía las obligaciones a entidades privadas esenciales/importantes; en España pendiente de transposición definitiva

6

RGPD + LOPDGDD exigen notificar brechas de datos en 72h a la AEPD y designar DPO en casos establecidos